

Business logic, security and process: open questions

We're building from Anas's architecture and his UI/UX direction. Anas owns the design, and we lean towards his aesthetic wherever there's a choice. This brief covers what is left to agree together: auction rules, money flow, security and process. Notes on the UI are collected at the end as suggestions for Anas to take or leave.

7 agenda items 12 decisions 9 security items 1 bug in the existing code

Already agreed

Anas's recommendations

- ◆ **Anas leads UI/UX**, using his visual identity: cream, navy and gold, with Playfair Display and Inter. His lot page prototype is the reference for layout and interactions.
- ◆ **Stack**: Next.js + TypeScript + Tailwind, Postgres on Supabase (Mumbai), Vercel, Cloudflare R2 for photos, and `pg_cron` or a scheduled function for closing auctions. Notifications start with email and SMS, with WhatsApp later.
- ◆ **Bid design**: one locked database transaction per bid, an idempotency key, the client sends the price it saw, the server owns the end time, and bids after `ends_at` are always rejected.
- ◆ **Conventions**: times stored in UTC and shown in PKT, prices in integer rupees, and bids are append-only.
- ◆ **Process**: a `CLAUDE.md` with the rules, thin build slices, a commit after each working step, preview deploys, a separate staging environment, the bid function tested hardest, a dedicated security pass, and one outside human review before launch.
- ◆ **WhatsApp link previews** on lot pages (photo, title, price).

Agenda

- 1 Starting point and review process** D1 · D2
How the business rules already written and tested in our earlier code feed into Anas's build, and who signs off on money-related changes.

 - 2 Auction rules** D3 · D4 · D5
Maximum (proxy) bids, how anti-sniping works, and which rules staff can change in admin.

 - 3 Money and trust flow** D6 · D7 · D8
Custody, the client account, deposits, fees, the payment deadline, defaults and seller payouts.

 - 4 Bidders: login, eligibility, privacy** D9 · D10 · D11
Email or phone login, who may bid in the pilot, and paddle numbers.

 - 5 Promises to buyers** D12
Viewing before bidding, and wording that has to match how we actually operate.

 - 6 Security** Part 3
Supabase access rules, Realtime payloads, rate limits, admin access and payment fraud.

 - 7 Process flow and next steps** Parts 4–5
The end-to-end lot lifecycle, and the order of work after tonight.
-

Decisions to make tonight

Each decision has the question, why it matters and a recommendation. Where a decision affects the UI, there's a short note for Anas. How it looks stays his call.

D1 Do we reuse the business logic from our earlier code?

The earlier code is unreleased and on the same stack as Anas's architecture: Next.js, Postgres, phone OTP, a locked-row bid function, closing and invoicing, and admin flows for custody, deposits, invoices and payouts. It has tests covering 60 simultaneous bids, increments, reserve, soft close, bid limits and fee maths. None of it is user-facing, so Anas's UI can sit on top.

Recommendation

Anas builds the UI his way. Carry the database functions, fee maths and their tests across rather than rewriting them, because they are the part that's hardest to get right without a programming background. Anything we drop is a deliberate choice, not an oversight.

D2 Who signs off on changes to bidding and money logic?

Anas will build with Claude Code or Cursor. His document names the risk: mistakes that can't be read. The UI can move fast. Bid placement, closing, invoices, deposits and payouts handle real money.

Recommendation

All changes go through pull requests. A change to bid, close or money logic needs passing tests plus a second founder's approval. Book the outside developer review before the pilot sale, not after.

D3

Do we have maximum (proxy) bidding in the MVP?

The architecture defers it, and the prototype is single-amount bidding: once you lead, you can't bid again. Our earlier code already has it working and tested. It lets busy collectors leave a ceiling instead of watching the clock, which matters for evening closes. It also changes the rules copy, the confirm step and the outbid messages.

Include (already built)

Defer, single bids only

Recommendation

Include it, because the work is done. If we defer, the rules must say plainly that there is no auto-bidding, and a leader must still be able to raise their own bid.

For Anas: if included, the bid field becomes "Your maximum bid", there's a "Raise my maximum" state, and a bid can lose instantly ("Another bidder's maximum is higher").

D4

Anti-snipe: add 5 minutes, or reset to 5 minutes?

The architecture says a late bid "extends the end time by 5 minutes". Our earlier code **resets** the end to *now + 5 minutes*. A bid at 4:30 left gives 9:30 under the first rule and 5:00 under the second. The engine, the prototype's copy and the rules page have to agree.

Reset to 5:00

Add 5:00

Recommendation

Reset to 5:00. It's the common auction-house rule and keeps endings tight. Make the window a per-lot setting (default 5 minutes), and word every mention as "resets the clock to 5 minutes".

D5

Which rules can staff change in admin, and when?

The architecture wants increment tiers, the anti-snipe window and the payment deadline editable in admin. If someone edits the increments during a live auction, the minimum next bid changes in the middle of bidding, and bidders see different rules from one minute to the next.

Recommendation

Editable in admin, but locked to each lot when it's published, so changes only apply to new lots. Every change goes in the audit log.

D6

Is the full middle-man model in the MVP?

The architecture's admin covers "mark paid, mark collected". It doesn't mention the trust layer the pilot is designed around:

- the watch is in our custody before it's listed
- buyers pay a segregated client account, never the seller
- deposits and bid limits
- a CNIC check at collection
- the seller's signed no-shill agreement, with the seller's own account blocked from bidding
- the seller is paid only after the buyer has paid and collected

Recommendation

Yes. This is what makes Nilaam different from an Instagram sale. Add it to the architecture document so it's built in from day one (see the lifecycle in Part 4).

D7

What are the fees, and does the bidder see the total before confirming?

The plan so far is a 7.5% buyer's premium (minimum PKR 15,000) and a 5% seller commission. The prototype's confirm step shows only the hammer amount. A winner who first learns about the premium on the invoice is a dispute waiting to happen.

Recommendation

Confirm the fee numbers tonight. The confirm step shows the bid, the premium and the total (for example PKR 390,000 + PKR 29,250 = PKR 419,250), with a link to the bidding terms. Tax treatment on the invoice is still pending legal advice (s.236A).

D8

Payment: deadline, how winners get bank details, and what happens on default

Bug in our earlier code: it sets payment due 3 *calendar* days after close, but all our copy promises 3 *business* days. A Friday-evening win would show as overdue on Monday. Separately, the prototype says "We send the account details by message", which is exactly how payment-diversion scams work: a fraudster sends "updated" bank details on WhatsApp.

Recommendation

- **Deadline:** 3 business days, with Pakistani public holidays configurable.
- **Bank details:** shown only inside the signed-in account. Every message says "Nilaam will never send you new bank details by message."
- **On default:** suspend the buyer, forfeit the deposit (full mode), and offer the watch to the underbidder or relist it.

D9

Login: email first, as Anas suggests, and where does the phone number fit?

Anas recommends email login for the MVP because SMS OTP to Pakistani numbers is costly and unreliable. That's a fair point. But several business rules key off the phone number: tracking which WhatsApp group a bidder came from, blocking the seller's own number from bidding on their watches, and contacting winners.

Email login + verified phone to bid

Email only

Phone login, code by email or WhatsApp

Recommendation

Go with Anas's email login, and require a verified phone number before a bidder's first bid. This keeps seller-blocking and invite tracking working. Choose the SMS or WhatsApp provider for that one-time check.

D10

Who can bid in the pilot, and when do we tighten it?

The pilot plan is invite-only through WhatsApp groups, with verified contact details, a bid limit set by staff, and the CNIC checked at collection. Later, full mode adds a refundable deposit (5% of the limit, minimum PKR 50,000, giving a limit of 20× the deposit) and a CNIC check before bidding. The prototype's "You pay nothing to bid" is only true in pilot mode.

Recommendation

Confirm the pilot rules and the switch-over triggers: the first outside seller, the first non-payment, or opening beyond the invite list. The page wording follows whichever mode is on.

D11

Paddle numbers or chosen handles in bid history?

Anas's prototype shows paddle numbers ("Bidder 4821"). Our earlier code had bidders choose a public handle. In a small WhatsApp community, people can recognise handles, which invites "who's bidding against me", collusion and side deals.

Recommendation

Go with Anas's paddle numbers. Decide whether a number is per account or per lot. Per lot is more private, but makes repeat bidders harder for staff to follow, so staff would still see the real account in admin.

D12

Do we offer viewing before bidding?

The prototype's trust strip says "Inspect first: view before you bid". The current plan is inspection at collection, before the buyer signs, plus a viewing event for the launch sale.

Offer appointments in Karachi

Inspect at handover only

Recommendation

Keep the promise only if someone will staff appointments, and decide who and when. Otherwise the line becomes "Inspect at handover: check the watch before you sign for it."

Security concerns

must means fix before the pilot sale. **should** means build alongside.

must **Lock down Supabase access rules.** Every Supabase project exposes its tables through an automatic API, using a key that's meant to be public in the browser. Anas's stack uses that browser client for Realtime. Enable row-level security on every table, and give the browser no direct access to bids, users, reserves, CNICs or money tables. This is the first item in Anas's own security pass, so make it a launch checklist item.

must **Realtime payloads carry public fields only.** Broadcast the current price, bid count, reserve met (yes or no), end time and paddle numbers. Never broadcast the reserve amount, anyone's maximum bid, or a bidder's real identity. Send broadcasts from the server after the bid commits, not by streaming table changes to the browser.

must **Keep secret keys on the server.** The Supabase service key, the encryption key for CNICs and the cron secret never appear in browser code or in variables the browser can read.

must **Check admin access on the server for every admin route and action,** not just by hiding links. Separate staff and admin roles, require 2FA for staff, and audit-log every money, KYC and status action.

must **Rate-limit login codes and bids** per IP and per account. OTP endpoints are a common target, and every abused SMS costs money.

must **Never send bank details by message (D8).** Confirm every payment against the bank statement before marking it paid.

must **Get the outside review** of bid logic and access rules before money moves. This is Anas's step 6.

should **Don't show "you're winning" optimistically.** Anas's plan updates the UI before the server answers. That's fine for "Placing bid...". But with maximum bids, a bid can lose instantly to a hidden higher maximum, so only the server's answer should say "You're the highest bidder".

should **Strip EXIF and GPS data from photos on upload to R2,** and photograph watches only in the studio, never at the seller's home. Photo metadata can reveal where expensive watches are kept.

Process flow: the life of a lot

This is the end-to-end flow the pilot plan assumes. The architecture document covers steps 6 to 9. The open question under each step is for tonight.

- 1 Seller enquiry and intake.** The watch arrives at our premises and is logged against the seller.
Who receives the watch, and where is it stored?
- 2 Authentication and condition report.** Case opened, movement checked, timegrapher reading, stolen-register check, grade S-D.
Who is our specialist? What happens to a watch that fails: returned, with a fee?
- 3 Studio photos and description.**
Real photos of this exact watch. The prototype's images look like brand marketing renders, which isn't acceptable for a live lot.
- 4 Custody and agreement.** The watch is recorded in custody and the seller's no-skill agreement is signed. The lot can't be published without both.
Who drafts the seller agreement?
- 5 Scheduling.** Starting price, reserve (agreed in writing), duration, anti-snipe window, ending in the evening PKT and staggered.
How long do auctions run? (Plan: 7 days.)
- 6 Bidding.** Eligible bidders only (D10), maximum bids (D3) and anti-snipe (D4).
- 7 Close.** The server closes the lot, creates the invoice (hammer + premium) and notifies the winner.
If the reserve isn't met, can staff agree a sale with the top bidder afterwards, through Nilaam?
- 8 Payment.** The buyer pays the client account within the deadline (D8), and staff confirm it against the bank statement.
- 9 Handover.** CNIC checked, the buyer inspects and signs, and custody is released.
- 10 Seller payout.** Hammer minus 5% commission, paid only after payment *and* collection, with the transfer reference recorded.
How many days after collection do we pay the seller?

11

Exceptions. Default (suspend, forfeit, offer to the underbidder), deposit refunds (blocked while bids or invoices are open), and claims under the 12-month authenticity guarantee.

Who handles a guarantee claim, and who pays if the seller has already been paid?

What the lot page has to say

These are the business facts the page must show. How it shows them is Anas's call.

Information the bidder needs

must

Premium and total before confirming, plus the bidding terms link (D7).

must

Every state of the page: signed out, not eligible (with the reason: verify phone or email, limit not set, suspended, you consigned this watch), upcoming, no reserve, and ended, showing "Sold for PKR X" or "Not sold". Public results build trust.

should

The bidder's available bid limit, with a clear block when a bid is over it.

should

The lot's name in the confirm step. The mobile sticky bar can open it before the bidder has seen the title.

should

A check for typos in the amount. In testing, 3,900,000 instead of 390,000 went straight to a normal confirm. Warn when a bid is far above the current price.

should

End date and time in PKT, and days in the countdown, because lots run 7 days.

should

The seller's description, tags (Box & papers, Unpolished case...), and failed or n/a checks in the condition report, not only passes.

should

Lakh and crore next to PKR ("3.85 lakh"). It's how most buyers say prices.

Wording that has to match how we operate

Prototype or architecture wording	Issue	Suggested wording
"Extends the auction by 5 minutes"	Depends on D4.	"A bid in the last 5 minutes resets the clock to 5 minutes, so everyone can respond."
"You pay nothing to bid"	Only true in pilot mode (D10).	Pilot: as is. Full mode: "Bidding needs a refundable deposit."

Prototype or architecture wording	Issue	Suggested wording
"We send the account details by message"	Fraud risk. It also leaves out the premium and the deadline.	"Pay the hammer price plus 7.5% buyer's premium to Nilaam's client account within 3 business days. Details are in your account. We never send bank details by message."
"Collect the watch from our storage location"	Leaves out the CNIC requirement and the inspect-and-sign step.	"Collect in Karachi with your CNIC. Inspect the watch before you sign for it."
"Inspect first: view before you bid"	Depends on D12.	"Inspect at handover", unless we staff viewings.
"Inspected by our lead watch specialist"	A named person is more credible.	The specialist's name, the inspection date and "in Nilaam's custody".

UI notes for Anas

These came from testing the prototype in a browser at desktop, laptop and phone sizes. They're offered as observations. Anas decides.

note

On desktop the price and clock scroll away while you read the condition report. The sticky bid bar only appears on mobile.

note

On a 1280×720 laptop the bid card is taller than the screen, so the title and price slide under the header.

note

Long-press save and share is blocked on the photos. Buyers may want to send a photo to a friend on WhatsApp. A fullscreen pinch-zoom view would complement the magnifier.

note

Dark mode: the prototype is light only.

note

Keyboard and screen reader: tabs can't be reached with the arrow keys and aren't linked to their panels. The status note and the toast announce the same message twice.

note

Small tap targets: the menu button (38×34) and the "12 bids" link (51×22) are under 44 px.

note

Small details: the lot number appears three times; the mobile section heading says "Specifications" while the desktop tab says "Details"; the footer says "Vintage watch auctions" for a 2020 watch.

After tonight

Proposed order of work

1. Record D1–D12, and add the trust layer (D6) and the lot lifecycle (Part 4) to the architecture document.
2. Set up the repo with `CLAUDE.md`, staging and production on Supabase and Vercel (Mumbai), with row-level security on from the first table.
3. Carry across the bid, close and fee logic with its tests (D1). Apply D3, D4, D5 and the business-day deadline (D8).
4. Login (D9) and the provider for codes and notifications.
5. Anas builds the lot page and admin in his design, covering everything in Part 5.
6. Photo upload to R2 with EXIF stripping, and WhatsApp link previews.
7. Security pass (Part 3), then the outside review, then the invitation-only pilot sale.

Sources: Anas's lot page prototype (HTML), "Nilaam MVP Architecture" (4 Oct 2026), and our earlier unreleased MVP code and planning documents. The full reviews are in the repo under docs/.